

SIMATS ENGINEERING
CO5 ASSESSMENT TOOL 3
APPLICATION-BASED QUESTIONS (High)

Course: ETHICAL HACKING	Code: ITA1416	CO: CO5
Duration:	Total Marks: 100	Reg No / Name : G.RAJU (192411065)

COURSE OUTCOME COVERED

***CO5:** Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: Answer all questions. Each question carries 20 marks.

1. Real time Scenario: You are assessing a Windows network where NULL sessions are enabled.

Question: In this situation, how would you critically evaluate the security risks introduced by NULL sessions? Walk me through how you would approach enumerating users, groups, and shared resources using this access. Based on your findings, how would you determine the severity of the risk? Additionally, explain how you would translate these technical findings into business terms so that a non-technical manager understands the potential impact on confidentiality and organizational security.

I would check what information is exposed through anonymous NULL sessions, such as usernames, groups, domain details, and shared resources. I would assess whether this information enables further attacks such as password guessing or access to sensitive shares.

The risk is higher if confidential resources or privileged account information are exposed. In business terms, it can reveal internal information that helps attackers compromise organizational systems.

2. Real time Scenario: During a penetration test, you identify several systems exposing RPC services.

Question: How would you analyze the security implications of exposed RPC ports across multiple systems? Describe your approach to identifying underlying vulnerabilities associated with these services. How would you evaluate which vulnerabilities are worth exploiting, considering factors such as exploit reliability, potential impact, and engagement scope? Explain how you would prioritize your actions and justify your decisions.

I would identify the RPC services, versions, configurations, and associated vulnerabilities using authorized scanning and vulnerability databases. I would prioritize remotely exploitable vulnerabilities with high impact and reliable exploitation. I would avoid risky exploits on production systems and use safe validation where possible. The final priority would depend on exploitability, impact, and engagement scope.

3. Real time Scenario: You have successfully gained access to a system through SMB.

Question: Given this foothold, how would you evaluate the different lateral movement techniques available within the network? Discuss how you would compare methods such as credential reuse, pass-the-hash, or remote execution techniques. How would you decide which approach to use, considering detection mechanisms, network architecture, and potential impact? Provide a reasoned justification for your chosen strategy.

I would assess available techniques such as credential reuse, pass-the-hash, and authorized remote execution. I would compare them based on privileges required, reliability, detection likelihood, network segmentation, and impact. I would select the least invasive technique that demonstrates the risk. I would avoid unnecessary actions that could disrupt systems or trigger excessive alerts.

4. Real time Scenario: A critical server is found to have weak or overly permissive share permissions.

Question: How would you evaluate whether these misconfigurations could lead to privilege escalation or unauthorized access to sensitive data? Explain how you would validate exploitability without disrupting the system. Furthermore, describe how you would assess the business impact of this issue and present your findings to stakeholders in a way that supports remediation decisions.

I would identify who has read/write access and determine whether sensitive files or privileged service files are writable. I would safely validate the issue using a test file rather than modifying critical data. If low-privileged users can modify files executed by privileged processes, the risk is High. The business impact could include data theft or administrative compromise.

5. Real time Scenario: An organization continues to use SMBv1 due to legacy application requirements.

Question: How would you evaluate the security risks associated with continuing to use SMBv1, especially in the context of known exploits? Discuss how you would balance these risks against business and operational constraints. What alternative mitigation strategies would you recommend, and how would you justify them to both technical teams and management?

SMBv1 is obsolete and has serious known security weaknesses, including vulnerabilities associated with attacks such as EternalBlue. I would recommend disabling it and upgrading dependent applications. If it cannot immediately be removed, I would use segmentation, firewall restrictions, patching, and monitoring. Management should understand that keeping SMBv1 increases the chance of widespread compromise.

6. Real time Scenario: You are performing reconnaissance within a Windows domain environment.

Question: How would you evaluate different information-gathering techniques in terms of their effectiveness and likelihood of detection? Discuss both active and passive approaches, and explain how you would select methods that provide maximum intelligence while minimizing alerts. Justify your strategy based on the security controls typically present in enterprise environments.

I would use both passive and active reconnaissance. Passive methods such as asset inventories and existing logs generate less detection and network traffic, while active enumeration provides

more current information but may trigger security controls. I would begin with passive methods and use controlled active enumeration only where necessary.

7. Real time Scenario: You have obtained access using a low-privilege account.

Question: How would you evaluate the various privilege escalation opportunities available in a Windows environment? Describe how you would analyze system configurations, misconfigurations, and credential exposure. How would you decide which escalation path to pursue while minimizing detection risk and ensuring reliability?

I would check system configurations, user privileges, services, scheduled tasks, file permissions, software versions, and exposed credentials. I would prioritize reliable and lowimpact escalation paths such as configuration weaknesses over unstable exploits. The selected approach should provide sufficient evidence while minimizing system disruption and unnecessary detection.

8. Real time Scenario: A system is suspected to be vulnerable to EternalBlue.

Question: How would you evaluate the accuracy and reliability of this assessment before attempting exploitation? Describe the validation techniques you would use and the precautions you would take to avoid system instability. Based on your findings, how would you decide on the next steps and justify your approach?

I would verify the operating-system version, SMB configuration, patch status, and vulnerability-scanner results before attempting exploitation. I would use safe vulnerability checks rather than immediately running a potentially unstable exploit. If multiple sources confirm the vulnerability, I would document the risk and recommend patching or isolation.

9.Real time Scenario: A Linux server has multiple open ports and running services.

Question: How would you evaluate which of these services are most likely to be exploitable? Explain how you would analyze service versions, configurations, and exposure levels. How would you prioritize your testing efforts and justify your decisions?

I would identify the services running on each open port and examine their versions, configurations, privileges, and network exposure. Outdated, externally accessible services with known vulnerabilities receive the highest priority. Unnecessary services should be disabled or restricted. Manual verification should confirm important scanner findings.

10.Real time Scenario: You identify misconfigured NFS shares in a Linux environment.

Question: How would you evaluate whether these shares can be exploited for unauthorized access or privilege escalation? Describe how you would safely demonstrate the risk during a penetration test without affecting system availability. How would you justify the severity of this issue?

I would examine exported shares, client restrictions, and read/write permissions. I would check whether sensitive files can be accessed or modified by unauthorized users. A controlled test file can be used to demonstrate the issue safely. Broad write access or access to privileged files could make the vulnerability High or Critical.

11.Real time Scenario: .rhosts or hosts.equiv files are discovered on a system.

Question: How would you evaluate their security implications in a modern environment? Explain how you would determine whether these trust relationships can still be abused. How would you justify whether this represents a critical vulnerability or a low-risk finding?

These files can create weak trust relationships between systems and may allow access without strong authentication. I would determine whether the trusted hosts still exist and whether the trust mechanism is active. If privileged access is possible, the risk is High/Critical; if the files are inactive or unused, the risk may be Low.

12.Real time Scenario: Several files and directories have 777 permissions.

Question: How would you evaluate whether these permissions can lead to privilege escalation or system compromise? Describe your process for identifying sensitive files and validating potential exploitation paths. Justify how you would rate the risk.

I would identify which sensitive files or directories have 777 permissions and determine whether low-privileged users can modify them. Special attention should be given to scripts, executables, configuration files, and scheduled-task files. If a privileged process executes a world-writable file, privilege escalation may be possible. Therefore, severity depends on the file's function and privileges.

13.Real time Scenario: A buffer overflow vulnerability is identified in a Linux application.

Question: How would you evaluate whether this vulnerability is practically exploitable in the given environment? Discuss factors such as memory protections, exploit complexity, and reliability. How would you justify whether exploitation is feasible or not?

I would evaluate whether the vulnerable input is remotely reachable and whether exploitation is practical. I would consider protections such as ASLR, NX, stack canaries, PIE, and RELRO, along with exploit reliability. A vulnerability may exist but still be difficult to exploit because of these protections. I would safely validate it before concluding its severity.

14.Real time Scenario: You have gained initial access to a Linux system.

Question: How would you evaluate your next steps in terms of information gathering, persistence, and lateral movement? Explain how you would balance achieving objectives with maintaining stealth and avoiding detection. Justify your priorities.

After gaining access, I would identify the system, current privileges, network configuration, services, sensitive files, and possible credentials. I would then assess persistence and lateral movement opportunities only if they are within scope. I would use the minimum necessary actions to achieve the testing objective while avoiding unnecessary changes or disruption.

15.Real time Scenario: A Linux system is running multiple background services.

Question: How would you evaluate which services are unnecessary or pose security risks? Describe how you would analyze their purpose, exposure, and configuration. How would you justify your recommendations for disabling or securing them?

I would identify running services, determine their business purpose, and check their ports, versions, configurations, and privileges. Unnecessary or outdated network-facing services increase the attack surface. I would recommend disabling unnecessary services and hardening required ones. Changes should be tested first to avoid affecting business applications.

16.Real time Scenario: A login form appears vulnerable to SQL injection.

Question: How would you evaluate the severity of this vulnerability? Explain how you would safely confirm its presence and assess its potential impact on the database and application. How would you justify your risk rating?

I would safely test whether user input is incorporated into database queries without proper parameterization. I would assess whether authentication bypass or unauthorized database access is possible without extracting real sensitive data. SQL injection affecting sensitive financial information is generally High or Critical. Parameterized queries and least-privilege database accounts are key mitigations.

17.Real time Scenario: An XSS vulnerability is identified in a web application.

Question: How would you evaluate its real-world impact, particularly in terms of session hijacking and user data exposure? Describe how you would demonstrate this vulnerability to a client in a controlled manner. Justify how you would communicate its severity.

I would determine whether the XSS is stored, reflected, or DOM-based and identify which users can be affected. I would demonstrate it using a harmless proof of concept rather than stealing real session data. The impact can include account compromise, unauthorized actions, and user-data exposure. Severity increases when privileged users are affected.

18.Real time Scenario: Both stored and reflected XSS vulnerabilities are present.

Question: How would you evaluate and compare their risks in practical attack scenarios? Discuss factors such as persistence, user interaction, and impact. Which type would you consider more critical, and why?

Stored XSS is generally more dangerous because the malicious content persists in the application and can affect multiple users. Reflected XSS usually requires the victim to interact with a crafted request or link. I would normally rate stored XSS higher, especially when administrators or many users are affected.

19.Real time Scenario: You are testing a web application for CSRF vulnerabilities.

Question: How would you evaluate whether existing defenses (such as tokens or headers) are effective? Explain how you would test their robustness and assess the likelihood of successful exploitation. Justify your conclusions.

I would check whether sensitive requests require valid CSRF tokens and whether those tokens are properly validated. I would also examine SameSite cookies and relevant origin protections. I would use controlled test accounts to verify whether unauthorized state-changing requests are possible. Effective server-side validation is essential.

20.Real time Scenario: Session IDs are found to be predictable.

Question: How would you evaluate the feasibility of exploiting this weakness? Describe how you would assess the likelihood of session hijacking and its potential impact on users and the organization. How would you justify the business risk?

I would assess session ID length, randomness, uniqueness, expiration, and whether IDs change after authentication. Testing should use controlled accounts rather than attempting to hijack real users. If an attacker can predict valid sessions, account takeover and unauthorized transactions may occur. For financial applications, this could be a High or Critical business risk.

21.Real-Time Scenario:A corporate Windows network includes legacy systems where SMBv1 is still enabled due to application dependencies.Security scans indicate that these systems are vulnerable to known exploits such as EternalBlue.Network segmentation is weak, allowing communication between critical and non-critical systems.

Question: How would you evaluate the risk associated with SMBv1 vulnerabilities, analyze the feasibility of exploitation in this network, compare the potential impact of worm-based attacks versus targeted attacks, assess the role of network segmentation in limiting damage, and justify a mitigation strategy that balances operational constraints with security requirements?

This is a Critical-risk scenario because vulnerable SMBv1 systems can potentially be compromised and weak segmentation allows attackers to move between systems. Worm-based attacks could spread automatically, while targeted attacks focus on high-value systems. I would recommend disabling SMBv1, patching systems, segmenting legacy systems, restricting SMB traffic, and monitoring the environment.

22.Real-Time Scenario:A Linux server exposes multiple services including FTP, SSH, and HTTP, some of which are outdated and poorly documented.Port scanning reveals unusual open ports that are not part of standard configurations.System administrators have limited visibility into running services.

Question: How would you analyze the attack surface created by exposed services, evaluate which services are most likely to be exploitable, compare automated scanning tools with manual verification techniques, assess the risk of unknown services, and justify your prioritization of remediation efforts based on exploitability and impact?

I would inventory all services, including unusual ports, and determine their versions, configurations, privileges, and business purpose. Automated scanners are useful for broad discovery, while manual verification confirms important findings and reduces false positives.

Unknown services should receive priority because they are unmanaged attack surfaces. Critical and externally exposed vulnerabilities should be remediated first.

23.Real-Time Scenario: An internal penetration test reveals that NFS shares are exported with weak permissions and no proper restrictions.Sensitive configuration files are accessible from multiple client systems.No logging mechanism is implemented to track access to these shares.

Question: How would you evaluate the risk posed by misconfigured NFS shares, analyze whether these shares can lead to privilege escalation or data leakage, compare different exploitation approaches, assess the impact of lack of logging on detection capabilities, and justify your severity classification and remediation recommendations?

I would check who can access the shares, whether write access is available, and whether sensitive files are exposed. Controlled testing can demonstrate unauthorized access without modifying production data. Lack of logging makes attacks harder to detect and investigate. The issue should be rated High if sensitive information or privileged files are exposed.

24.Real-Time Scenario: A web application connected to a backend database is found to have input fields that do not validate user inputs properly. Preliminary testing suggests the possibility of SQL injection attacks.The application stores sensitive customer financial data.

Question: How would you evaluate the severity of the SQL injection vulnerability, analyze the extent of database compromise possible, compare error-based, union-based, and blind injection techniques, assess the business impact of data exposure, and justify your recommendations for secure coding and database protection mechanisms?

I would safely confirm whether input can alter database queries and determine the potential scope of database access. Error-based, union-based, and blind injection differ in how database information can potentially be inferred or retrieved. Because financial information is involved, successful SQL injection could cause severe confidentiality and integrity issues. Parameterized queries, input validation, least privilege, and secure database configuration are required.

25.Real-Time Scenario:A Windows system is configured with several services running under SYSTEM privileges, and some service executables are located in writable

directories.No integrity checks are enforced on service binaries.Users with low privileges have access to modify certain directories.

Question: How would you evaluate the possibility of privilege escalation through service misconfiguration, analyze the attack vectors involving binary replacement or path hijacking, compare different exploitation techniques, assess detection risks, and justify your mitigation strategy including secure service configuration and monitoring?

I would check whether low-privileged users can modify service executables, directories, or DLL-loading paths for services running as SYSTEM. Binary replacement or path hijacking may allow privilege escalation if these conditions exist. I would validate the issue with a safe proof of concept. The main fixes are proper file permissions, least-privilege service accounts, secure service paths, integrity monitoring, and configuration monitoring.

Code of Conduct:

*I **G.RAJU (192411065)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

G.RAJU

Signature of the student:

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all requirements	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem	
Application of Concepts	30	Accurately applies appropriate concepts to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts	
Problem-Solving Approach	20	Logical, wellstructured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach	
Accuracy of Solution	20	Completely correct solution with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution	
Clarity	10	Clear, wellorganized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand	